VIBE CODER SECURITY GUIDE

OWASP TOP 10

Security Checklist

The 10 biggest security risks — explained for non-technical builders, vibe coders & AI app builders.

WHAT IS OWASP?

OWASP (Open Web Application Security Project) is a nonprofit that publishes the world's most trusted list of critical web security risks.
The 2025 edition analyzed 175,000+ CVE records & reflects AI-era threats.
It's the gold standard for app security — now including AI-built apps.

HOW TO USE THIS CHECKLIST

- Read each risk — even if you're just vibing and using AI to build.
- Check off every item you've addressed in your app.
- Anything unchecked = potential vulnerability to fix ASAP.
- Use this before launching and after any major feature update.

CHECKLIST KEY

Good — addressed | In progress | Not done yet

OWASP Top 10 Checklist

01 ■ Broken Access Control

WHAT IT MEANS:
Your app lets people see or do things they shouldn't — now includes server tricking (SSRF).

QUICK FIX:
Every page and action must check 'is this person allowed here?' Deny by default. Never trust user-submitted IDs alone.

- [ ] Users can only access their own data
- [ ] Admin pages require real permission checks
- [ ] Server can't be tricked into fetching internal URLs

02 ■■ Security Misconfiguration

WHAT IT MEANS:
Your app or cloud is set up with default or unsafe settings. This jumped to #2 — it now affects 90% of apps.

QUICK FIX:
Audit every setting. Turn off what you don't need. Change all defaults. Hide error details from end users.

- [ ] Default usernames/passwords have been changed
- [ ] Error messages don't expose internal details
- [ ] Cloud storage buckets and permissions are locked down

03 ■ Software Supply Chain Failures

WHAT IT MEANS:
NEW in 2025: The tools and packages you build with could be compromised before you even download them.

QUICK FIX:
Only use packages from official sources. Verify integrity with checksums. Keep a list (SBOM) of everything you use.

- [ ] Dependencies come from official, trusted sources
- [ ] You have a list of all packages your app uses (SBOM)
- [ ] CI/CD pipeline verifies package signatures

04 ■ Cryptographic Failures

WHAT IT MEANS:
Sensitive data (passwords, credit cards, tokens) isn't properly scrambled and protected.

QUICK FIX:
Always encrypt sensitive data in storage AND transit. Use modern, strong encryption. Never use old algorithms like MD5.

- [ ] Passwords are hashed (bcrypt/argon2), never stored plain
- [ ] Your site uses HTTPS everywhere
- [ ] No sensitive data in URLs or logs

05 ■ Injection

WHAT IT MEANS:
Hackers sneak malicious code into your app through input fields — SQL, commands, AI prompts, and more.

QUICK FIX:
Never trust user input. Use parameterized queries and safe libraries. Applies to AI prompts too — validate everything.

- [ ] Database queries don't use raw user input
- [ ] User input is validated and sanitized before use
- [ ] AI prompt inputs are filtered for injection attempts

OWASP Top 10 Checklist

06 ■■ Insecure Design

WHAT IT MEANS:
Security wasn't thought about from the start — flaws are baked into the architecture itself.

QUICK FIX:
Think 'what could go wrong?' before you build. Map out how a bad actor could misuse each feature.

- [ ] You've mapped abuse cases for key features
- [ ] Password resets require real identity verification
- [ ] Sensitive flows have rate limiting built in

07 ■ Authentication Failures

WHAT IT MEANS:
Your login system is weak — easy to break, bypass, or brute-force. Includes AI-assisted attacks now.

QUICK FIX:
Use multi-factor authentication. Rate limit failed logins. Never allow weak or default passwords.

- [ ] Multi-factor authentication (MFA) is available
- [ ] Failed login attempts are rate limited
- [ ] Sessions expire after inactivity and on logout

08 ■ Software & Data Integrity Failures

WHAT IT MEANS:
Your app blindly trusts code, data, or updates without checking they haven't been tampered with.

QUICK FIX:
Verify integrity of everything coming from outside — use digital signatures and checksums before trusting.

- [ ] Auto-updates verify digital signatures
- [ ] User cookies/tokens aren't deserialized without validation
- [ ] CDN scripts use Subresource Integrity (SRI) checks

09 ■ Logging & Alerting Failures

WHAT IT MEANS:
You have no idea when something bad is happening — no logs, no alerts, no visibility.

QUICK FIX:
Log key events (logins, errors, access). Set up real-time alerts for suspicious activity. Review logs regularly.

- [ ] Failed logins and errors are being logged
- [ ] Alerts fire for unusual login patterns
- [ ] Logs are stored securely and tamper-proof

10 ■ Mishandling Exceptional Conditions

WHAT IT MEANS:
NEW in 2025: When your app hits an error or crash, it accidentally lets people in instead of locking down.

QUICK FIX:
Always 'fail closed' — if something goes wrong, deny access by default. Never let an error become an open door.

- [ ] Errors and crashes result in access denied, not access granted
- [ ] Error messages show generic text to users, not stack traces
- [ ] Edge cases and unusual inputs are tested regularly

Your Security Action Plan

Use this page to plan what you're fixing next.

■ Fix These NOW

Critical — your app could be breached today.

- [ ] Broken Access Control
- [ ] Security Misconfiguration
- [ ] Authentication Failures
- [ ] Injection

■ Fix These Soon

Important — address in your next update.

- [ ] Cryptographic Failures
- [ ] Software Supply Chain Failures
- [ ] Insecure Design

■ Build These In

Embed in your process — especially for AI apps.

- [ ] Software & Data Integrity Failures
- [ ] Logging & Alerting Failures
- [ ] Mishandling Exceptional Conditions

NOTES

Follow @itsthatladydev to learn to build secure apps with AI ■

Keep building. Keep learning. Keep it secure. ■

Follow for more dev content: @itsthatladydev · itsthatlady.dev